

CSEC 742 Final Project

Group 6

April 27, 2026

Contents

1	Organization Overview	3
2	Group Members	3
3	Network Topology	4
4	System Inventory	5
5	Subnet and VLAN Allocation	6
5.1	Subnet and VLAN Design	6
5.2	Security and Design Rationale	6
6	Operating System and Application Selection	7
7	Security Controls Implemented	8
7.1	Wazuh SIEM & XDR	8
7.2	CIS Benchmarks	8
7.3	Active Directory Domain Services	8
7.4	OpenVPN	9
7.5	Windows Defender Firewall	9
7.6	Uncomplicated Firewall (UFW)	9
8	MITRE ATT&CK Analysis	10
8.1	Technique 1: <i>T1110 - Brute Force</i>	10
8.2	Technique 2: <i>T1133 - External Remote Services</i>	11
8.3	Technique 3: <i>T1053 - Scheduled Task / Job</i>	14
8.4	Technique 4: <i>T1136 - Create Account</i>	16
8.5	Technique 5: <i>T1190 - Exploit Public-Facing Application</i>	18
9	Cyber Threat Intelligence (CTI) Analysis	20
9.1	Applicable Threat Description	20
9.2	Detection and Prevention Assessment	20

1 Organization Overview

Organization Name

FoodBar

Mission Statement

FoodBar delivers quality grocery products to its customers while maintaining secure and efficient technology systems to protect business operations and internal data.

2 Group Members

- Name: Jacob Austin
Degree Program: Cybersecurity BS/MS
Graduation Year: 2026
- Name: Ella Carbone
Degree Program: Computer Science BS/Cybersecurity MS
Graduation Year: 2026
- Name: Blake Hinkley
Degree Program: Computer Science BS/Cybersecurity MS
Graduation Year: 2026
- Name: Roberto Reade
Degree Program: Cybersecurity BS/MS
Graduation Year: 2026
- Name: Ben Sippel
Degree Program: Computer Science BS/Cybersecurity MS
Graduation Year: 2026

3 Network Topology

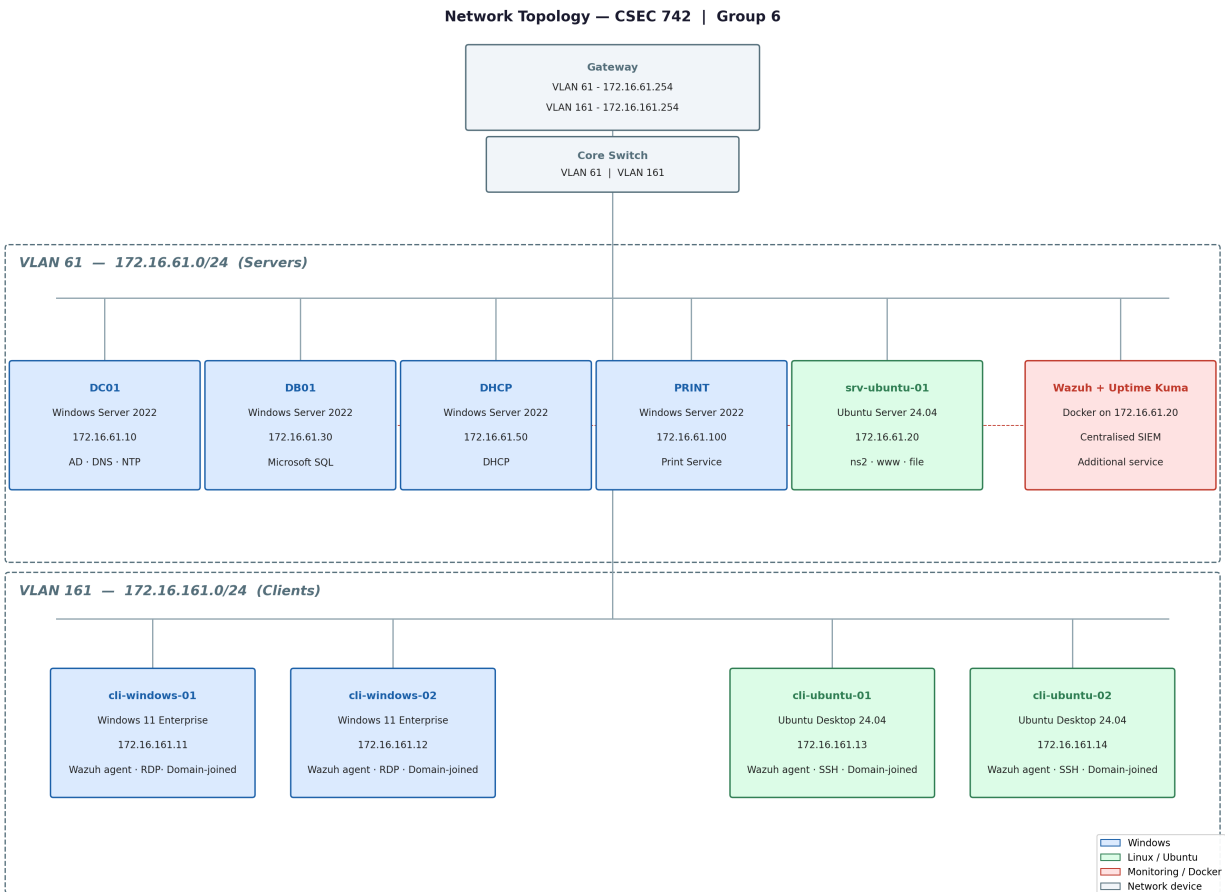


Figure 1: Network Topology Diagram

4 System Inventory

The following table provides a comprehensive inventory of the systems, including their operating system versions, primary purposes, key applications and services with their respective versions, and the primary users of each system.

System	OS & Version	Purpose	Key Services / Apps (Versions)	Primary Users
dc01 / ns1 / time	Windows Server 2022 Version 21H2	Primary Domain Controller, DNS, NTP	Active Directory Domain Services, DNS, NTP	All domain users, IT admins
srv-ubuntu-01 / ns2 / file / www	Ubuntu 24.04.4 LTS	Web server, file server, secondary DNS, Docker host	Nginx 1.24.0, vsftpd 3.0.5, BIND 9.18.39, Docker Engine 29.3.1, Wazuh Manager, Indexer & Dashboard 4.14.4 (Docker), Wazuh Agent 4.14.4 (on all endpoints), Uptime Kuma 1.23.17 (Docker)	Employees, IT admins
db01	Windows Server 2022 Version 21H2	Database server	Microsoft SQL Server 2022 (16.0.1000.6)	Backend services, IT admins
dhcp	Windows Server 2022 Version 21H2	DHCP server	Windows DHCP Server Role	All network devices, IT admins
print	Windows Server 2022 Version 21H2	Print services	Windows Print Services Role	Employees, IT admins
cli-windows-01/ cli-windows-02	Windows 11 Version 25H2	Windows workstations	Microsoft Office, AD client services, OpenSSH 9.6p1	Employees, IT admins
cli-ubuntu-01/ cli-ubuntu-02	Ubuntu 24.04.4 LTS	Linux workstations	Developer tools, OpenSSH 9.6p1	Developers, IT

Figure 2: System Inventory List

5 Subnet and VLAN Allocation

The network was segmented into two VLANs and subnets separating server and client infrastructure.

5.1 Subnet and VLAN Design

- **VLAN 61- Server Network**

Subnet: 172.16.61.0/24

Gateway: 172.16.61.254

Purpose: Hosts all core infrastructure/ server systems.

Systems:

- 172.16.61.10- Active Directory Domain Controller, Primary DNS, NTP
- 172.16.61.20- Web Server, File Server, Secondary DNS, MDR, Docker
- 172.16.61.30- Database Server
- 172.16.61.50- DHCP Server
- 172.16.61.100- Print Server (DHCP reservation)

- **VLAN 161- Client Network**

Subnet: 172.16.161.0/24

Gateway: 172.16.161.254

Purpose: Hosts all end-user systems.

Systems:

- 172.16.161.11- Windows Client 1
- 172.16.161.12- Windows Client 2
- 172.16.161.13- Ubuntu Client 1
- 172.16.161.14- Ubuntu Client 2

5.2 Security and Design Rationale

Separating servers and clients on different VLANs reduces the exposure of critical server resources to threats coming from compromised end-user devices. Additionally, restricting access between subnets is easier than managing complex access control rules between specific devices on the same subnet. Operationally, having separate VLANs simplifies troubleshooting and reduces the network traffic processed by endpoints since broadcast traffic is contained within the VLAN. Servers also tend to handle a larger volume of traffic, so assigning devices based on function to different VLANs allows for server subnet configurations that prioritize server traffic without affecting or being delayed by client activity. Finally, regulations relevant to retail organizations, such as PCI DSS, require strict data controls, and separating servers that store sensitive data into a specific VLAN enables simpler auditing and control of traffic between zones.

6 Operating System and Application Selection

This section details the rationale behind the selection of specific operating system and application/service versions, highlighting the reasons for their choice and the security benefits they provide. The selections prioritize stability, long-term support, compatibility, and robust security features.

System / Service	Version Chosen	Why This Version Was Selected	Security Benefit
Active Directory / Domain Controller	Windows Server 2022 Version 21H2	Stable Windows Server with long-term support and full AD, DNS, and NTP feature set	Centralized authentication and authorization, enables access control, logging, and policy enforcement with AD DS
Primary DNS	Windows Server 2022 Version 21H2 DNS (AD-Integrated)	Cross-platform reliability and redundancy	Reduces single point of failure and performs reliable name resolution for internal services
Secondary DNS	BIND 9.18.39 (Ubuntu 24.04)	Cross-platform reliability and redundancy	DNS redundancy, fault tolerance, and service continuity
Web Server (Nginx)	nginx/1.24.0 (Ubuntu)	Long-term support and reliability, compatibility with other apps	Reduces attack surface with lightweight architecture and supports TLS configuration
File Server (FTP)	vsftpd 3.0.5	Lightweight and widely used FTP server on Linux	Controlled file transfer service, enables centralized file access control, restricts access for authorized users
Database Server	Microsoft SQL Server 2022 (16.0.1000.6) on Windows Server 2022 Version 21H2	Industry-standard database with high availability and strong support	Data access control enforcement, supports authentication, encryption, and transaction logging
DHCP	Windows Server 2022 Version 21H2	Stable Windows Server with long-term support and full DHCP feature set	Centralized IP allocation, enables network segmentation and device tracking
Print Server	Windows Server 2022 Version 21H2	Stable Windows server with long-term support, offers native AD integration and centralized management	Centralized print job management, supports access control, and reduces device exposure on the network
Linux Servers	Ubuntu 24.04.4 LTS	Stable and widely used enterprise Linux distribution	Stable OS base, supports secure remote administration and minimal attack surface
Windows Clients	Windows 11 Version 25H2	Stable OS with AD and Group Policy support	Group Policy and domain-based security controls, offers centralized patching and endpoint management
Linux Clients	Ubuntu 24.04.4 LTS	Stable OS and compatibility with server environment	Environment with strong permission separation and SSH-based administration support
Docker (MDR container)	29.3.1 Docker Engine	Actively maintained with frequent updates and high compatibility	Service isolation, reduced attack surface, easy patching and rollback
Monitoring / SIEM (Wazuh)	4.14.4	Open-source SIEM/XDR with bug fixes, latest features, and active support	Real-time alerts, updated threat detection, MITRE ATT&CK coverage, detailed log analysis
Uptime Monitoring (Uptime Kuma)	1.23.17	Lightweight, self-hosted monitoring tool for service availability with active support	Real-time uptime monitoring, alerting on service failures, improves system reliability and supports incident response with low overhead
OpenSSH	OpenSSH 9.6p1 (Ubuntu package 3ubuntu13.14)	Secure remote administration service with active patching and strong cryptographic support	Secures remote administration with encrypted SSH protocol, reduces risk of credential theft and unauthorized access
OpenVPN	OpenVPN 2.6.19	Stable and widely deployed VPN solution for secure remote access and tunneling	Encrypts network traffic over untrusted networks, offers secure remote access, and protects against eavesdropping

Figure 3: Operating System and Application Selection Rationale List

7 Security Controls Implemented

7.1 Wazuh SIEM & XDR

Wazuh was deployed as a Docker container on the Ubuntu server and serves as the primary security monitoring and detection platform for the environment. Wazuh agents were installed on all domain-joined Windows and Linux endpoints, providing centralized log collection, real-time alerting, and endpoint visibility from a single dashboard. The platform provides built-in detection rules mapped directly to MITRE ATT&CK techniques, covering brute force attempts across SSH, RDP, and SQL services, unauthorized account creation, scheduled task modifications, and suspicious process execution. File Integrity Monitoring was configured on critical system directories and the nginx web root to detect unauthorized file modifications indicative of web shell deployment or ransomware activity. The Vulnerability Detection module continuously scans all agents against the NVD CVE database, providing ongoing awareness of unpatched software across the infrastructure. Wazuh's Active Response capability was configured to automatically block source IPs upon detection of repeated authentication failures, providing an automated layer of response without requiring manual intervention.

7.2 CIS Benchmarks

CIS Benchmark recommendations were applied across both Windows and Linux systems to establish a hardened baseline configuration consistent with industry best practices. On Windows systems, benchmark guidance was implemented through Group Policy Objects applied domain-wide, ensuring consistent enforcement across all domain-joined clients and servers without requiring per-host configuration. Key controls implemented include account lockout policies requiring lockout after repeated failed authentication attempts, password complexity and minimum length requirements, and auditing policies that ensure security-relevant events are logged and forwarded to Wazuh for correlation. On Linux systems, CIS benchmark guidance informed the configuration of file permissions, service restrictions, sudo logging, and SSH hardening parameters including the disabling of root login and restriction of permitted authentication ciphers. Scheduled task and cron access was restricted to trusted users only, with auditing enabled to detect unauthorized task creation or modification.

7.3 Active Directory Domain Services

Microsoft Active Directory Domain Services was deployed on Windows Server 2022 as the central identity and access management platform for the environment, providing authentication, authorization, and policy enforcement for all domain-joined systems. All Windows clients, Windows servers, and Linux clients were joined to the domain, with Group Policy used extensively to push security configurations domain-wide including firewall rules, audit policies, password policies, and software restrictions, ensuring that security controls are consistently enforced regardless of individual host configuration. Account creation was restricted to privileged administrative groups, ensuring that unauthorized account provisioning is prevented by design and that all account creation events are logged and visible to

Wazuh. Role-Based Access Control was enforced through AD security groups, limiting user and service account permissions to only what was required for their designated function.

7.4 OpenVPN

OpenVPN was deployed to provide secure remote access to the internal network, eliminating the need to expose RDP, SSH, and SMB services directly to external networks. By requiring remote users to authenticate through the VPN tunnel before accessing any internal services, OpenVPN ensures that remote access is encrypted, authenticated, and restricted to authorized users. This significantly reduces the attack surface of the environment by ensuring that services like RDP and SSH, which are common targets for brute force and exploitation, are not directly reachable without first establishing an authenticated VPN session. OpenVPN's use of certificate-based authentication provides a stronger authentication mechanism than password-only remote access, and all VPN connection events are logged and forwarded to Wazuh for monitoring and alerting on anomalous access patterns.

7.5 Windows Defender Firewall

Windows Defender Firewall was configured on all Windows servers and Windows client machines as a host-based network filtering layer, providing granular control over inbound and outbound traffic at the individual host level. Firewall rules were managed centrally through Group Policy rather than configured per-host, ensuring consistent enforcement across the domain and eliminating the risk of misconfigured or missing rules on individual machines. Inbound rules were scoped to specific source subnets and required service ports only, following a principle of least-privilege approach to network access. This ensures that even if an attacker gains a foothold within the network, lateral movement is restricted by host-level firewall rules that limit which hosts can communicate with which services. All firewall rule changes are logged and visible through Wazuh's Windows Event Log collection, providing an audit trail of any policy modifications.

7.6 Uncomplicated Firewall (UFW)

UFW was configured on the Ubuntu server as the host-based firewall for all Linux infrastructure, enforcing a default-deny inbound policy with explicit allow rules for only the services required for operation. Permitted inbound traffic was restricted to SSH on port 22, HTTP on port 80, HTTPS on port 443 for the Wazuh dashboard, Uptime Kuma on port 3001, vsftpd FTP on ports 20 and 21, and the Wazuh manager agent communication ports 1514 and 1515, with all other inbound connections dropped by default. This ensures that the Ubuntu server, which hosts the nginx web server, Wazuh Docker container, Uptime Kuma availability monitor, and vsftpd file transfer service, presents the smallest possible network attack surface by permitting only traffic explicitly required for each deployed service. UFW rule changes and blocked connection attempts are logged to syslog and collected by the local Wazuh agent, providing visibility into connection attempts against the Linux infrastructure alongside the Windows event data in the centralized Wazuh dashboard.

8 MITRE ATT&CK Analysis

8.1 Technique 1: *T1110 - Brute Force*

MITRE ATT&CK defines T1110 as an adversary systematically attempting passwords to gain access to accounts when the correct credentials are unknown. Attackers will:

- Repeatedly guess passwords
- Use password spraying
- Crack password hashes offline
- Perform credential stuffing using breached password lists

Brute force can target any endpoints and services that use authentication including SSH, RDP, SMB, FTP, SQL Server, LDAP, Kerberos, and web login portals.

8.1.1 Active Directory

- Account lockout policy prevents unlimited attempts
- Group Policy enforces password complexity
- Centralized authentication reduces the number of brute-force targets

8.1.2 CIS Benchmarks

NGINX

- 5.2.4 - Limit number of connections per IP
- 5.2.5 - Rate limits by IP address
- 5.1.1 - Allow/Deny filters restrict to specific IPs
- 3.1 - Ensure detailed logging is enabled
- 3.2 - Ensure access logging is enabled
- 3.3 - Ensure error logging is enabled

Microsoft SQL Server 2022

- 3.1 - Server Authentication set to Windows Authentication Mode
- 2.11 - Use non-standard ports
- 2.12 - Hide SQL Server instance
- 2.13 - Disable the 'sa' login

- 2.14 - Rename the 'sa' login
- 2.16 - Ensure no login exists with the name 'sa'
- 4.1 - MUST_CHANGE for SQL logins
- 4.2 - CHECK_EXPIRATION for sysadmin logins
- 4.3 - CHECK_POLICY for all SQL logins
- 5.3 Login Auditing (failed logins)
- 5.4 Server Audit captures failed and successful logins

Windows Server 2022

- 1.1 - Password Policy
- 1.2 - Account Lockout Policy
- 2.3.1.4 - Ensure 'Accounts: Limit local account use of blank passwords to console logon only' is set to 'Enabled'
- 17.1.1 - Audit Credential Validation (Success and Failure)
- 17.5.1 - Audit Account Lockout (Failure)

Ubuntu Linux 24.04

- 5.1.16 - Ensure sshd MaxAuthTries is configured
- 5.3.3.3 - Ensure password reuse is limited
- 5.3.2.1 - Ensure password creation requirements are configured
- 7.2.1 - Ensure accounts in /etc/passwd use shadowed passwords

8.1.3 Wazuh

- SSH Brute-Force Detection
- Windows Logon / RDP Brute-Force Detection
- Web Authentication Brute-Force Detection

8.2 Technique 2: *T1133 - External Remote Services*

MITRE ATT&CK Technique T1133 refers to attackers abusing legitimate, internet-facing remote services, such as RDP and SSH, or exposed management interfaces to gain initial access and maintain persistence in a network. Attackers exploit misconfigured or weakly authenticated remote services to gain a foothold, often without deploying additional malware. In this infrastructure, externally accessible services include NGINX (web), OpenSSH (Ubuntu and Windows servers), RDP (Windows servers) making hardening of these endpoints critical.

8.2.1 Active Directory

- Group Policy restricts which accounts may log on through Remote Desktop Services
- Domain authentication ensures remote sessions require valid domain credentials
- Centralised access control limits lateral movement via remote services

8.2.2 CIS Benchmarks

NGINX

- 2.4.1 - Ensure NGINX only listens for network connections on authorised ports
- 4.1.1 - Ensure HTTP is redirected to HTTPS
- 4.1.4 - Ensure only modern TLS protocols are used
- 4.1.5 - Disable weak ciphers
- 4.1.8 - Ensure HTTP Strict Transport Security (HSTS) is enabled
- 5.1.1 - Ensure allow and deny filters limit access to specific IP addresses
- 5.2.4 - Ensure the number of connections per IP address is limited
- 5.2.5 - Ensure rate limits by IP address are set
- 3.1 - Ensure detailed logging is enabled
- 3.1 - Ensure access logging is enabled
- 3.3 - Ensure error logging is enabled and set to the info logging level

Microsoft SQL Server 2022

- 2.10 - Ensure unnecessary SQL Server Protocols are set to 'Disabled'
- 2.11 - Ensure SQL Server is configured to use non-standard ports
- 2.12 - Ensure 'Hide Instance' option is set to 'Yes' for Production SQL Server instances
- 7.4 - Ensure Network Encryption is Configured and Enabled

Windows Server 2022

- 2.2.10 - Ensure 'Allow log on through Remote Desktop Services' is set to 'Administrators' (DC only)
- 2.2.34 - Ensure 'Deny log on through Remote Desktop Services' to include 'Guests' (DC only)

- 2.2.35 / 2.2.36 - Ensure 'Deny log on through Remote Desktop Services' is set to 'Guests, Local Admins'
- 9.1.1 - Ensure 'Windows Firewall: Domain: Firewall state' is set to 'On'
- 9.2.1 - Ensure 'Windows Firewall: Private: Firewall state' is set to 'On'
- 9.3.1 - Ensure 'Windows Firewall: Public: Firewall state' is set to 'On'
- 9.3.2 - Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block'
- 18.10.56.3.9.1 - Ensure 'Always prompt for password upon connection' is set to 'Enabled'
- 18.10.56.3.9.3 - Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL'
- 18.10.56.3.9.4 - Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled'
- 18.10.56.3.9.5 - Ensure 'Set client connection encryption level' is set to 'Enabled: High Level'
- 20.55 - Ensure protection methods such as TLS, encrypted VPNs, or IPsec are used for remote connections
- 20.62 - Ensure 'Telnet Client is not installed'
- 20.64 - Ensure 'TFTP Client' is not installed
- 17.5.4 - Audit Logon (Success and Failure)
- 17.5.5 - Audit Other Logon/Logoff Events (Success and Failure)

Ubuntu Linux 24.04

- 2.2.6 - Ensure ftp client is not installed
- 4.2.3 - Ensure ufw service is enabled
- 4.2.6 - Ensure ufw firewall rules exist for all open ports
- 4.2.7 - Ensure ufw default deny firewall policy
- 5.1.1 - Ensure permissions on /etc/ssh/sshd_config are configured
- 5.1.4 - Ensure sshd access is configured
- 5.1.6 - Ensure sshd Ciphers are configured
- 5.1.8 - Ensure sshd DisableForwarding is enabled

- 5.1.13 - Ensure sshd LoginGraceTime is configured
- 5.1.17 - Ensure sshd MaxSessions is configured
- 5.1.18 - Ensure sshd MaxStartups is configured
- 5.1.20 - Ensure sshd PermitRootLogin is disabled
- 5.1.22 - Ensure sshd UsePAM is enabled
- 6.2.3.12 - Ensure login and logout events are collected

8.2.3 Wazuh

- SSH Remote Login Monitoring (unusual hours, geolocation anomalies)
- RDP / Windows Remote Logon Detection
- WinRM Lateral Movement Detection
- Failed Remote Authentication Alerting

8.3 Technique 3: *T1053 - Scheduled Task / Job*

MITRE ATT&CK defines T1052 as adversaries abusing task scheduling utilities to facilitate initial or recurring execution of malicious code or programs. On Windows, this includes the Task Scheduler and AT command; on Linux, cron, at, and systemd timers are targeted. Adveraries use scheduled tasks to achieve persistence, execute payloads at later times, or perform lateral movement.

8.3.1 Active Directory

- Group Policy restricts 'Log on as a batch job' and 'Log on as a service' rights to specific accounts
- Centralised audit policy captures process creation events, enabling detection of unexpected scheduled task execution
- Domain Group Policy can restrict or audit changes to the Task Scheduler service

8.3.2 CIS Benchmarks

Microsoft SQL Server 2022

- 2.2 - Ensure 'CLR Enabled' Server Configuration Option is set to '0'
- 2.5 - Ensure 'Ole Automation Procedures' Server Configuration Option is set to '0'
- 2.8 - Ensure 'Scan For Startup Procs' Server Configuration Option is set to '0'

- 2.17 - Ensure 'clr strict security' Server Configuration Option is set to '1'
- 3.6 - Ensure the SQL Server's SQLAgent Service Account is Not an Administrator
- 3.11 - Ensure the public role in the msdb database is not granted access to SQL Agent proxies
- 5.3 - Ensure 'Login Auditing' is set to 'failed logins'
- 5.4 - Ensure 'SQL Server Audit' is set to capture both failed and successful logins

Windows Server 2022

- 2.2.26 / 2.2.27 - Ensure 'Deny log on as a batch job' to include 'Guests'
- 2.2.26 2.2.27 - Ensure 'Deny log on as batch job' to include 'Guests'
- 2.2.28 / 2.2.29 - Ensure 'Deny log on as a service' to include 'Guests'
- 2.2.49 - Ensure 'Log on as a batch job' is set to 'Administrators' (DC only)
- 17.3.2 - Ensure 'Audit Process Creation' is set to include 'Success'
- 17.6.3 - Ensure 'Audit Other Object Access Events' is set to 'Success and Failure' (captures scheduled task creation and modification events)
- 17.8.1 - Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure'
- 18.9.3.1 - Ensure 'Include command line in process creation events' is set to 'Enabled'

Ubuntu Linux 24.04

- 2.4.1.2 - Ensure permissions on /etc/crontab are configured
- 2.4.1.3 - Ensure permissions on /etc/cron.hourly are configured
- 2.4.1.4 - Ensure permissions on /etc/cron.daily are configured
- 2.4.1.5 - Ensure permissions on /etc/cron.weekly are configured
- 2.4.1.6 - Ensure permissions on /etc/cron.monthly are configured
- 2.4.1.7 - Ensure permissions on /etc/cron.d are configured
- 2.4.1.8 - Ensure crontab is restricted to authorised users
- 2.4.2.1 - Ensure at is restricted to authorised users
- 6.2.3.6 - Ensure use of privileged commands are collected
- 6.2.3.6 - Ensure changes to system administration scope (sudoers) is collected

8.3.3 Wazuh

- Windows Scheduled Task Creation / Modification Detection
- Linux Cron Job Modification Monitoring (/etc/crontab, /etc/cron.* file-integrity monitoring)
- SQL Server Agent Job Creation Audit Log Monitoring
- Suspicious Process Execution from Scheduled Context Alerting

8.4 Technique 4: *T1136 - Create Account*

MITRE ATT&CK defines T1136 as adversaries creating accounts to maintain access to victim systems. With sufficient privilege, adversaries may create local OS accounts, domain accounts, cloud accounts, or application specific accounts to establish persistence and secondary access. Unlike backdoors, account creation uses legitimate functions of the environment to blend into the actual administrative activity and may persist long after the intrusion is remediated.

8.4.1 Active Directory

- Only Domain Admins and delegated administrators can create domain accounts
- Group Policy enforces password complexity and expiration for all created accounts
- Audit User Account Management policy captures account creation events across domain

8.4.2 CIS Benchmarks

Microsoft SQL Server 2022

- 3.1 - Ensure 'Server Authentication' Property is set to 'Windows Authentication Mode'
- 3.2 - Ensure CONNECT permissions on the 'guest' user is revoked within all SQL Server databases
- 3.3 - Ensure 'Orphaned Users' are dropped from SQL Server databases
- 3.9 - Ensure Windows BUILTIN groups are not SQL logins
- 3.10 - Ensure Windows local groups are not SQL logins
- 3.12 - Ensure the 'SYSADMIN' role is limited to administrative or built-in accounts
- 3.13 - Ensure no admin role membership in msdb database
- 4.1 - Ensure 'MUST_CHANGE' option is set to 'ON' for all SQL authenticated logins

- 4.2 - Ensure 'CHECK_EXPIRATION' option is set to 'ON' for all SQL authenticated logins
- 4.3 - Ensure 'CHECK_POLICY' option is set to 'ON' for all SQL authenticated logins
- 5.3 - Ensure 'Login Auditing' is set to 'failed logins'
- 5.4 - Ensure 'SQL Server Audit' is set to capture both failed and successful logins

Windows Server 2022

- 2.2.5 - Ensure 'Add workstations to domain' is set to 'Administrators' (DC only)
- 17.2.2 - Ensure 'Audit Computer Account Management' is set to include 'Success' (DC only)
- 17.2.4 - Ensure 'Audit Other Account Management Events' is set to include 'Success'
- 17.2.6 - Ensure 'Audit Security Group Management' is set to include 'Success'
- 17.2.7 - Ensure 'Audit User Account Management' is set to 'Success and Failure'
- 20.26 - Ensure 'Emergency accounts must be automatically removed or disabled after the crisis is resolved'
- 20.45 - Ensure 'Outdated or unused accounts are removed or disabled'
- 20.58 - Ensure 'Shared user accounts do not exist'
- 20.63 - Ensure 'Temporary user accounts must be automatically removed or disabled after 72 hours'
- 20.70 - Ensure 'Users with Administrative privileges have separate accounts for administrative duties'

Ubuntu Linux 24.04

- 6.2.3.8 - Ensure events that modify user/group information are collected
- 6.2.3.18 - Ensure successful and unsuccessful attempts to use the usermod command are collected
- 7.1.5 - Ensure permissions on /etc/shadow are configured
- 7.1.9 - Ensure permissions on /etc/shells are configured
- 7.2.1 - Ensure accounts in /etc/passwd use shadowed passwords
- 7.2.2 - Ensure /etc/shadow password fields are not empty
- 7.2.5 - Ensure no duplicate UIDs exist
- 7.2.7 - Ensure no duplicate user names exist
- 5.3.3 - Ensure password reuse is limited

8.4.3 Wazuh

- Windows User Account Creation Detection
- Linux useradd / adduser Command Execution Monitoring
- SQL Server Login Creation Audit Log Alerting
- Privileged Group Membership Change Detection

8.5 Technique 5: *T1190 - Exploit Public-Facing Application*

MITRE ATT&CK defines T1190 as adversaries attempting to exploit weaknesses in internet facing applications or services including: web servers, databases, and APIs. This is often through the use of malformed data and packets, injection payloads, or known CVEs. The objective is to obtain initial access or achieve remote code execution, privilege escalation, or data exfiltration without credentials.

8.5.1 CIS Benchmarks

NGINX

- 1.2.2 - Ensure the latest software package is installed
- 2.1.1 - Ensure only required dynamic modules are loaded
- 2.2.1 - Ensure NGINX runs using a non-privileged, dedicated service account
- 2.5.1 - Ensure server_tokens directive is set to 'off'
- 2.5.2 - Ensure default error and index.html pages do not reference NGINX
- 2.5.3 - Ensure hidden file serving is disabled
- 2.5.4 - Ensure the NGINX reverse proxy does not enable information disclosure
- 4.1.4 - Ensure only modern TLS protocols are used
- 4.1.5 - Disable weak ciphers
- 5.1.2 - Ensure only approved HTTP methods are allowed
- 5.2.1 - Ensure timeout values for reading the client header and body are set correctly
- 5.2.2 - Ensure the maximum request body size is set correctly
- 5.2.3 - Ensure the maximum buffer size for URIs is defined
- 5.3.1 - Ensure X-Content-Type-Options header is configured and enabled
- 5.3.2 - Ensure Content Security Policy (CSP) is enabled and configured properly
- 5.3.3 - Ensure the Referrer Policy is enabled and configured properly

8.5.2 Wazuh

- Web Application Attack Detection
- Known CVE Exploitation Signature Detection
- Anomalous HTTP Response Code Monitoring
- File Integrity Monitoring on NGINX web root and configuration directories
- Docker Container Breakout / Escape Detection

9 Cyber Threat Intelligence (CTI) Analysis

9.1 Applicable Threat Description

The Cybersecurity and Infrastructure Security Agency advisory on Akira¹, last updated in November of 2025, contains detailed threat intelligence on a ransomware group targeting small and medium-sized organizations, including those in retail sectors, that has been active since 2023. The CTI report describes the tactics, techniques, and procedures (TTPs) used by Akira's threat actors across the MITRE ATT&CK framework and provides indicators of compromise (IOCs), a list of publicly available tools and applications used in attacks, and recommended mitigations for organizations.

This CTI Report is highly relevant to FoodBar as a retail environment because operations rely on continuous uptime, handling sensitive customer data, and distributed endpoints. The challenges associated with securing this type of environment, including consistent enforcement of security controls across mixed Windows and Linux systems, remote access configurations, and centralized authentication requirements, make it a good target for ransomware attacks and particularly vulnerable to the TTPs used by Akira.

9.2 Detection and Prevention Assessment

Relevant MITRE ATT&CK Techniques

The key relevant MITRE ATT&CK Techniques identified in the Akira CTI report include:

- Initial Access:
 - T1078: Valid Accounts
 - T1133: External Remote Services
 - T1190: Exploit Public-Facing Application
 - T1566: Phishing
- Credential Access:
 - T1003: OS Credential Dumping
 - T1110: Brute Force
 - T1555: Credentials from Password Stores
- Privilege Escalation:
 - T1068: Exploitation for Privilege Escalation
- Lateral Movement
 - T1021: Remote Services

¹<https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-109a>

- T1550: Use Alternate Authentication Material
- Defense Evasion
 - T1027: Obfuscated Files or Information
 - T1036: Masquerading
 - T1222: File and Directory Permissions Modification
 - T1562: Impair Defenses
 - T1604: Proxy Through Victim
- Command and Control
 - T1090: Proxy
 - T1105: Ingress Tool Transfer
 - T1219: Remote Access Software
 - T1572: Protocol Tunneling
- Exfiltration
 - T1048: Exfiltration Over Alternative Protocol
 - T1537: Transfer Data to Cloud Account
 - T1567: Exfiltration Over Web Service

Environment Threat Mapping

Akira's TTPs map directly to components of FoodBar's infrastructure, demonstrating potential attack paths across the environment. Initial access is most likely to happen through exposed services like the web server on 172.16.61.20 because of its external accessibility or through attacks targeting Active Directory (172.16.61.10) credentials since it acts as the central authentication authority for FoodBar's entire network. Following initial access, Akira is reported to move laterally across systems using remote administration protocols that particularly threaten environments with limited network isolation since a compromised host may exist on the same VLAN as critical assets. In FoodBar's environment, the system hosting AD DS, the database server (172.16.61.30), and the file server (172.16.61.20) are primary targets for data exfiltration because of their role in storing authentication and sensitive customer data. Regarding endpoints, client-facing systems are often compromised through phishing attacks or credential theft, acting as the attacker's initial entry point into an organization's environment from which to attempt malicious actions like privilege escalation or lateral movement.

Environment Prevention/Detection of Identified Techniques

Initial Access

FoodBar’s controls for defending against initial access techniques such as phishing, exploitation of public-facing applications, and abuse of valid accounts include CIS benchmark hardening, Active Directory configurations, and detection through Wazuh. The externally facing NGINX web server is hardened according to CIS benchmarks, which includes TLS enforcement and restricted access controls, reducing exploitation risks (T1190). OpenVPN is used on all devices to enable secure remote access and encrypted communications (T1133). Active Directory enforces strong password and account policies to prevent credential-based attacks (T1078). Wazuh detects initial access events through monitoring authentication attempts, logs, and anomalous login behavior that can indicate phishing-related compromises (T1566).

Credential Access

Credential access techniques, like OS credential dumping (T1003) and stealing credentials from password stores (T1555), are mitigated by this environment through Active Directory and CIS benchmark configurations, including strong password policy enforcement and restriction of admin privileges. SSH hardening on Linux systems prevents exposure of credentials, while system logs on Windows devices provide visibility into authentication events. Wazuh offers strong detection through continuous monitoring of suspicious authentication events, brute-force attempts (T1110), privilege escalation, and OS credential dumping techniques.

Privilege Escalation

The environment mitigates privilege escalation (T1068) by implementing least privilege and role-based access control through Active Directory. CIS benchmark hardening includes disabling unused services and strictly limiting privileged executions. Wazuh can detect privilege escalation through monitoring and alerting admin to process execution, privilege changes, and anomalous system activities.

Lateral Movement

FoodBar’s security controls defend against lateral movement techniques like remote service use (T1021) and the use of alternate authentication material (T1550) through network segmentation and the implementation of access control policies. Separating clients and servers onto their own VLANs limits movement across FoodBar’s network while Active Directory enforces centralized authentication and restricts remote service access. Wazuh can detect lateral movement through monitoring login activity, anomalous authentication patterns, and suspicious tool usage.

Defense Evasion

This environment has several security controls in place to protect against defense evasion techniques, including the obfuscation of files or information (T1027), masquerading (T1036), and impairing defenses (T1562). CIS benchmark hardening includes logging, restricted file permissions, and the detection of unauthorized changes to files, configurations, and binaries. Wazuh performs file integrity monitoring (FIM) and real-time log ingestion containing evi-

dence of defense evasion across all systems, helping identify any attempts made by attackers to cover up malicious activity.

Command and Control

FoodBar's environment is able to prevent and detect command and control techniques like proxying (T1090), ingress tool transfer (T1105), and protocol tunneling (T1571) through firewall rules, network restrictions, and Wazuh monitoring. UFW and Windows Defender Firewall enforce default-deny policies and restrict outbound traffic, while Wazuh is able to flag suspicious outbound connections, network activity, and process executions associated with remote access tools. Alerts can be generated for such events that may be indicators of C2 activity.

Exfiltration

The environment's infrastructure has been constructed to satisfy detection and mitigation regarding the identified important exfiltration techniques. Core components of the infrastructure had their firewalls adjusted only as necessary for internal communication, proper firewall ruling in conjunction with segmentation can mitigate two key exfiltration methods (T1048, T1537). The file server itself can aid in mitigating all forms of exfiltration, including the remaining exfiltration method (T1067), through focused access control capabilities and authentication. All listed exfiltration techniques can be detected by our Wazuh installation, as anomalous or suspicious behavior related to sensitive data will be reported back to the primary manager which may then initiate related policies or protocols.